

Frameworks and Standards

This page describes how Project Compass aligns with the NIST AI Risk Management Framework, NIST SP 800-218A, and the OWASP Top 10 for LLM Applications, and how to interpret risk across these three frameworks.

Content Last Reviewed: July 2026

NIST AI Risk Management Framework

The NIST AI RMF, published in January 2023, is a voluntary framework that helps organizations manage risk across the lifecycle of an AI system. It is organized around four core functions.

Function 1: Govern

Establishes the organizational culture, policy, and accountability structures required to manage AI risk responsibly, including determining risk tolerance, assigning clear roles, formalizing AI risk policies, and training staff on foundational AI risk concepts.

Compass Support: The Compass questionnaire asks directly whether an organization maintains a written AI use policy, has designated a person accountable for AI governance, includes AI risk within regular risk reporting, and has trained staff on responsible AI use. These responses establish the accountability record that the Govern function requires.

Function 2: Map

Establishes the context in which an AI system operates and identifies the risks and impacts associated with each system and use case, including categorizing AI tools, identifying affected stakeholders, documenting data sources, and assessing organizational exposure.

Compass Support: The log based discovery process identifies which AI tools are actively in use within an environment, along with their category, vendor, and associated risk level. This is where the Map function is fulfilled in practice.

Function 3: Measure

Evaluates identified AI risks in detail, including considerations of bias, explainability, robustness, and privacy, and tracks residual risk over time.

Compass Support: The monitoring and data handling questions within the questionnaire, covering active monitoring, human review of outputs, and protection of sensitive data, produce a gap score reflecting an organization's current maturity relative to its target posture.

Function 4: Manage

Prioritizes and addresses identified risks through treatment plans, monitoring protocols, and ongoing documentation.

Compass Support: The Compass report presents remediation recommendations in priority order. The inventory approval workflow, through which each tool is designated as approved, under review, or blocked, maintains a documented record of every management decision.

NIST released a companion playbook alongside AI 100-1 that provides practical guidance for each of these functions. A related publication, NIST AI 600-1, addressing generative AI, was released in July 2024 and covers risks specific to large language models. For the latest publications, refer to airc.nist.gov.

NIST SP 800-218A: Secure Software Development for AI

NIST SP 800-218A extends the Secure Software Development Framework to address the specific challenges of building AI and machine learning systems, including model training, data pipelines, and generative AI integrations.

PO, Prepare the Organization

Establishes security requirements for AI systems prior to development, along with the roles, tools, and policies specific to AI and machine learning work.

Compass Relevance: Collecting organizational and role information during setup helps identify who is accountable for AI governance decisions.

PW, Produce Well-Secured Software

Designs and implements AI systems with appropriate security controls, including data validation, model integrity checks, and output filtering.

Compass Relevance: The discovery process flags tools with missing data controls, and the questionnaire addresses common model security practices.

PS, Protect the Software

Protects AI models, datasets, and pipelines from unauthorized access, tampering, and supply chain compromise throughout their lifecycle.

Compass Relevance: Supply chain risk is reflected in the inventory through vendor flagging and risk tiers assigned to third party tools.

RV, Respond to Vulnerabilities

Identifies, prioritizes, and remediates vulnerabilities in AI systems and their dependencies, including those discovered after deployment.

Compass Relevance: The Compass report orders remediation recommendations by severity to support this prioritization.

OWASP Top 10 for LLM Applications, 2025

The OWASP Top 10 for LLM Applications (2025, Version 2.0) identifies the most critical security risks specific to systems built on large language models. The following describes which of these risks Compass is able to surface through log analysis.

Risk	Detected
LLM01:2025, Prompt Injection: Adversarial input manipulates AI behavior, including hidden instructions embedded in retrieved content.	Partially. Unusual traffic volume to LLM APIs may indicate an attempt, though content is not inspected.
LLM02:2025, Sensitive Information Disclosure: AI output inadvertently reveals personal information, credentials, or confidential details.	Partially. Tools handling confidential data are flagged; response content is not inspected.
LLM03:2025, Supply Chain Risk: Vulnerabilities introduced through third party models, datasets, or pre-trained components.	Yes. The AI inventory lists every third party vendor and tool in use.
LLM04:2025, Data and Model Poisoning: Training data is corrupted to introduce backdoors, bias, or harmful behavior.	Not detected. Requires inspection of training pipelines, outside the scope of log analysis.
LLM05:2025, Improper Output Handling: A downstream system accepts AI output without validation, enabling injection attacks.	Not detected. Requires inspecting how an application processes AI output.
LLM06:2025, Excessive Agency: An AI agent is granted more permissions or autonomy than necessary.	Partially. Agentic tools capable of autonomous action are flagged as critical risk.
LLM07:2025, System Prompt Leakage: Confidential system instructions are exposed to end users.	Not detected. Requires inspection of application level requests and responses.
LLM08:2025, Vector and Embedding Weaknesses: Attacks against retrieval systems, including tampered data stores.	Partially. Common retrieval and vector database tools are detected; the attacks themselves are not.
LLM09:2025, Misinformation: AI produces plausible but factually incorrect output.	Not detected. Evaluating accuracy requires human judgment.
LLM10:2025, Unbounded Consumption: AI workloads consume resources without limits.	Yes. Unusually high call volume is reflected clearly in log analysis.

The OWASP Top 10 for LLM Applications is a living document maintained by the community. Refer to the official project page for the most current version, as new risks and rankings are released periodically.

Compass Risk Classification

Each AI tool identified through log analysis is assigned a risk tier based on three factors: the potential for data exposure, external connectivity, and the type of AI capability the tool provides.

Critical

Presents a direct risk of data leaving the organization, or the tool is capable of autonomous action. These tools process sensitive organizational data with minimal oversight. Examples include AI tools with file upload capability, agentic platforms, and unsanctioned AI data pipelines.

High

Involves meaningful data sharing with an external AI provider, or is likely to be used with confidential business content in the absence of a defined policy. Examples include AI writing assistants, code completion tools, and document summarizers.

Medium

Represents a moderate level of risk. These tools process external input through an AI provider but retain limited data, or operate under an established data handling agreement. Examples include AI enhanced search, sentiment analysis tools, and grammar assistants.

Low

Presents minimal risk. These tools operate locally, process anonymous input, or are governed by an established enterprise data processing agreement with defined access controls. Examples include on-device spell check and approved enterprise AI features with a signed data agreement.